



KENYA PRIVACY LAW REVIEW

DATA PROTECTION, PRIVACY & AI GOVERNANCE SERIES

PRACTICE NOTE SERIES

PRACTICE NOTE NO. 003

CROSS-BORDER DATA TRANSFERS:

*Legal, Privacy and Governance
Considerations for
Kenyan Organisations*



AUTHOR

Muchangi Patrick
Advocate

Technology Law • Data Protection •
Artificial Intelligence • Cybersecurity



PUBLISHED BY

Kenya Privacy Law Review (KPLR)



JULY 2026



REFERENCE: KPLR/PN/003/2026



ADVANCING EXCELLENCE IN

PRIVACY, TECHNOLOGY & DIGITAL GOVERNANCE

KENYA PRIVACY LAW REVIEW

Practice Note Series

Practice Note No. 003

CROSS-BORDER DATA TRANSFERS:

Legal, Privacy and Governance Considerations for Kenyan Organisations

Author

Muchangi Patrick

Advocate

Technology Law • Data Protection • Artificial Intelligence • Cybersecurity

Published by

Kenya Privacy Law Review (KPLR)

July 2026

Reference: KPLR/PN/003/2026

Advancing Excellence in Privacy, Technology & Digital Governance

Copyright © 2026 Muchangi Patrick. All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, transmitted, distributed, or adapted in any form or by any means, whether electronic, mechanical, photocopying, recording, or otherwise, without the prior written permission of the copyright holder, except for brief quotations used for purposes of review, commentary, research, teaching, or other uses permitted by applicable copyright law.

Publication Information

Cross-Border Data Transfers:

Legal, Privacy and Governance Considerations for Kenyan Organisations

Practice Note No. 003

Copyright

Copyright © 2026 **Muchangi Patrick**.

All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, transmitted, distributed, or adapted in any form or by any means, whether electronic, mechanical, photocopying, recording, or otherwise, without the prior written permission of the copyright holder, except for brief quotations used for purposes of criticism, review, research, teaching, or other uses permitted by applicable copyright law.

Published by

Kenya Privacy Law Review (KPLR)

An independent legal publication dedicated to privacy, technology law, artificial intelligence, cybersecurity, digital governance, and emerging technologies.

Author

Muchangi Patrick

Advocate

Technology Law • Data Protection • Artificial Intelligence • Cybersecurity

Recommended Citation

Muchangi Patrick, *Artificial Intelligence Procurement: Legal, Privacy and Governance Considerations for Kenyan Organisations*, **Kenya Privacy Law Review**, Practice Note No. 003 (July 2026).

Disclaimer

This Practice Note is published for general informational and educational purposes only. It provides independent legal analysis of selected issues relating to technology law, privacy, cybersecurity, artificial intelligence, and digital governance. It does not constitute legal advice and should not be relied upon as a substitute for legal advice tailored to specific facts and circumstances.

While every reasonable effort has been made to ensure the accuracy of the information contained in this publication as at the date of publication, the law may change over time. Readers are encouraged to obtain independent legal advice before acting on any information contained herein.

The views expressed are those of the author and do not necessarily reflect those of any regulator, institution, employer, client, or professional body.

Publication Details

Edition	First Edition
Publication Date	July 2026
Version	1.0
Reference	KPLR/PN/003/2026

Using a small table like this gives the page a clean, reference-book feel.

Contact

Muchangi Patrick

Advocate

Email: consult@dataprivacyadvocates.co.ke

LinkedIn: www.linkedin.com/in/patrick-muchangi-507498216

Website: dataprivacyadvocates.co.ke

This publication is issued as **KPLR Practice Note No. 003** and bears the publication reference **KPLR/PN/003/2026**, which serves as its official identifier for citation and reference purposes.

KENYA PRIVACY LAW REVIEW

Data Protection, Privacy & AI Governance Series

Muchangi Patrick & Associates Advocates · Nairobi, Kenya

PRIVACY & DATA PROTECTION

Kenya · July 2026 · Practice Note No. 3 (2026) · Ref. KPLR/PN/003/2026

Cross-Border Data Transfers: Legal, Privacy and Governance Considerations for Kenyan Organisations

Muchangi Patrick | Muchangi Patrick & Associates Advocates

Advocate of the High Court of Kenya · Privacy, Data Protection & AI Governance Specialist

COMPANION PRACTICE NOTES IN THIS SERIES

- Data Protection Impact Assessments: Managing High-Risk Processing Activities under Kenya's Data Protection Framework
- Personal Data Breach Management: Legal Duties, Regulatory Reporting and Incident Response in Kenya
- Artificial Intelligence Procurement: Legal, Privacy and Governance Considerations for Kenyan Organisations
- Data Protection Compliance Audits: Building Accountability under Kenya's Data Protection Framework

KEY TAKEAWAYS

- A cross-border transfer occurs functionally, not just formally: remote offshore access, disaster-recovery replication, and processing by a foreign-hosted SaaS platform all trigger the Data Protection Act's transfer regime, just as a formal outsourcing contract does.
- Sections 48–50 of the DPA establish a closed list of lawful grounds for transferring personal data outside Kenya — adequacy, appropriate safeguards, consent, or narrow necessity-based derogations. A transfer that fits none of these grounds is unlawful, however commercially necessary it may seem.
- GDPR compliance by a foreign vendor is evidence of appropriate safeguards, but does not itself satisfy the DPA: the Kenyan controller remains independently accountable and must be able to justify each transfer on Kenyan legal grounds.
- The ODPC's cross-jurisdictional cooperation with Uganda's Personal Data Protection Office in *Aaditi Rajput v Diamond Trust Bank* confirms that offshore group entities are not beyond the practical reach of Kenyan data protection accountability.

To cite: Muchangi Patrick, Cross-Border Data Transfers: Legal, Privacy and Governance Considerations for Kenyan Organisations, Kenya Practice and Law Review, Practice Note No. 3 (July 2026).

1. INTRODUCTION

Kenya's data economy is, by its nature, transnational. Cloud infrastructure, software-as-a-service platforms, payment processors, human resources systems, customer relationship management tools and, increasingly, artificial intelligence services routinely move personal data across borders as an ordinary incident of doing business. A Nairobi-based bank's core banking system may run on servers in Ireland; a Kenyan hospital's patient-records vendor may host data in the United States; a Kenyan employer's payroll and HR analytics may be processed by a subsidiary in South Africa or by a global platform with server infrastructure in multiple jurisdictions at once. Each of these ordinary commercial arrangements constitutes a cross-border transfer of personal data, and each triggers a discrete set of legal obligations under Kenya's data protection framework.

This Practice Note examines those obligations in depth. It situates the Data Protection Act, 2019 (“the DPA”) and the Data Protection (General) Regulations, 2021 (“the General Regulations”) within Kenya's broader constitutional and regulatory architecture, analyses the legal grounds on which personal data may lawfully leave Kenyan jurisdiction, and translates these requirements into a practical compliance methodology for boards, in-house counsel, Data Protection Officers, and compliance functions. Throughout, the Note draws comparative reference to the European Union's General Data Protection Regulation (“GDPR”), the African Union Convention on Cyber Security and Personal Data Protection (“the Malabo Convention”), and emerging international standards, while keeping the analysis firmly anchored in the Kenyan statutory text and the guidance of the Office of the Data Protection Commissioner (“the ODPC”).

The central thesis of this Note is that cross-border transfer compliance in Kenya is not a single event but a lifecycle: it begins with accurate data mapping, proceeds through legal-basis and risk assessment, is operationalised through

contractual safeguards, and continues through ongoing monitoring for as long as the transfer relationship subsists. Organisations that treat cross-border transfer compliance as a one-off contractual exercise — inserting a clause and moving on — routinely underestimate both their legal exposure and the reputational and commercial consequences of getting this wrong.

PRACTICAL INSIGHT

Cross-border transfer risk is frequently invisible to the business units that create it. A marketing team subscribing to a US-based email platform, or an HR team adopting a global talent-management tool, is initiating a cross-border transfer of personal data just as surely as a formal outsourcing arrangement negotiated by procurement and legal. Data Protection Officers should treat vendor onboarding — not only contract signature — as the trigger point for transfer compliance.

2. THE LEGAL AND REGULATORY FRAMEWORK

Kenya's regulation of cross-border data transfers rests on a layered framework: constitutional guarantees that inform the purpose and limits of the regime; the Data Protection Act, 2019 and its subsidiary regulations, which supply the operative rules; sector-specific statutes that impose parallel or more stringent requirements in regulated industries; and international and regional instruments that, while not directly enforceable in Kenyan courts, increasingly shape regulatory expectations and commercial practice.

2.1 Constitution of Kenya, 2010

Article 31 of the Constitution guarantees every person the right to privacy, including the right not to have information relating to their family or private affairs unnecessarily required or revealed, and the right not to have the privacy of their communications infringed. The Data Protection Act is properly understood as legislation enacted to give effect to this constitutional right, and Kenyan courts and the ODPC have consistently interpreted the Act through that constitutional lens. This matters for cross-border transfers in a specific way: because the right to privacy is a constitutional guarantee rather than a mere statutory entitlement, a transfer of personal data outside Kenya's jurisdiction cannot be treated as a private commercial matter falling outside constitutional scrutiny. A data controller who exports personal data to a jurisdiction with materially weaker safeguards may be found to have failed in its constitutional duty to protect the data subject's privacy, independently of any contractual arrangement it has made with the foreign recipient.

The Constitution's guarantees of equality and freedom from discrimination (Article 27), human dignity (Article 28), consumer protection (Article 46), and fair administrative action (Article 47) are also engaged where cross-border processing feeds into automated or algorithmic decision-making that affects Kenyan data subjects — for example, credit scoring performed by an offshore processor, or eligibility determinations generated by a foreign-hosted system. These constitutional dimensions reinforce, rather than substitute for, the statutory transfer regime discussed below.

2.2 The Data Protection Act, 2019

The DPA is the primary legislative instrument governing cross-border data transfers. Sections 25 to 30 set out the foundational data protection principles — lawfulness, fairness and transparency; purpose limitation; data minimisation; accuracy; storage limitation; integrity and confidentiality; and accountability — all of which continue to apply to personal data after it has left Kenyan territory. A controller does not discharge its obligations under these principles merely by transferring data abroad; it remains accountable for ensuring that the principles are honoured throughout the data's lifecycle, wherever it is processed.

Sections 48 to 50 of the DPA contain the operative cross-border transfer regime, discussed in detail in Chapter 4 below. In outline, the Act permits transfers where the Cabinet Secretary has confirmed that the receiving country has an adequate level of data protection, where the controller or processor has put in place appropriate safeguards (including contractual clauses) and the data subject has enforceable rights and effective remedies, or where one of a limited set of derogations applies. Section 50 imposes heightened conditions on the transfer of data revealing sensitive

categories of information or data relating to certain strategic interests, and preserves the Cabinet Secretary's power to prescribe categories of data that must additionally be processed on a server or data centre located in Kenya.

2.3 The Data Protection (General) Regulations, 2021

The General Regulations operationalise several aspects of the Act's transfer regime, including registration requirements for data controllers and processors, the documentation expected to demonstrate compliance, and the ODPC's expectations regarding Data Protection Impact Assessments for higher-risk processing — a category into which many cross-border arrangements fall, particularly those involving special categories of data, large-scale processing, or novel technologies. The Regulations also elaborate the rights of data subjects (access, rectification, erasure, objection, and restriction) which a controller must be able to honour even where the data has been exported, a practical requirement that shapes the contractual safeguards discussed in Chapter 8.

2.4 Sector-Specific Regimes

Several regulated sectors impose parallel or additional constraints on cross-border data movement. The Central Bank of Kenya's prudential guidelines and the Banking Act impose confidentiality obligations on customer information and, in practice, expect banks to maintain robust oversight of offshore outsourcing arrangements, including core banking and cloud hosting. The Kenya Information and Communications Act and sector regulations administered by the Communications Authority of Kenya impose confidentiality obligations on telecommunications operators in respect of subscriber data. The Health Act and associated regulations impose confidentiality obligations over patient information that inform how healthcare providers may lawfully engage offshore electronic health record and telemedicine vendors. Where sector rules are more restrictive than the general DPA regime, organisations in regulated industries must comply with the more stringent standard.

2.5 International and Regional Instruments

Kenya is a signatory to the African Union Convention on Cyber Security and Personal Data Protection (the Malabo Convention), which, once fully in force among ratifying states, is intended to support intra-African data flows on the basis of comparable protection standards. The GDPR, while not directly applicable to Kenyan controllers absent an establishment or targeting nexus in the European Union, remains the most influential comparative model for Kenya's transfer regime — the DPA's adequacy, safeguards, and derogations structure closely mirrors the GDPR's own architecture under Articles 44 to 49. Other instruments of comparative relevance include the OECD Privacy Guidelines, APEC's Cross-Border Privacy Rules system, and ISO/IEC 27701 as a certifiable privacy information management standard that increasingly features in vendor due diligence.

PRACTICAL INSIGHT

Although Malabo Convention ratification and the GDPR are not directly enforceable in Kenya, multinational counterparties increasingly expect Kenyan organisations to demonstrate alignment with these frameworks as a condition of commercial engagement. Organisations with cross-border operations or ambitions should treat international standards as governance benchmarks that shape contractual leverage and market access, not as optional best practice.

3. THE CONCEPT AND SCOPE OF “TRANSFER” UNDER KENYAN LAW

A recurring source of confusion in practice is the assumption that a “cross-border transfer” occurs only where an organisation deliberately and formally sends a data file to a counterparty abroad. In fact, the concept is considerably broader, and Kenyan organisations should assess transfer risk functionally rather than formally. A transfer occurs, for these purposes, wherever personal data collected or generated in Kenya is made accessible to, stored by, or processed by a person or system located outside Kenya — including remote access to a Kenya-hosted database by offshore support staff, replication of data to an offshore disaster-recovery site, processing by a global SaaS platform whose servers sit outside Kenya, and disclosure to a foreign parent company or affiliate for group reporting purposes.

The Data Protection Act applies extraterritorially in a complementary sense: Section 4 extends its application to the processing of personal data by a data controller or processor not resident in Kenya where it processes personal data of data subjects located in Kenya. This means that a foreign vendor receiving data exported from Kenya is not outside the reach of Kenyan law simply because its own operations sit offshore — it, too, may fall within the DPA's scope, and Kenyan organisations should factor this into contractual risk allocation rather than assuming that legal responsibility ends at the border.

Organisations should therefore begin any transfer compliance exercise with a functional data flow map: identifying every system, vendor, subsidiary, and support function that can access Kenyan personal data from outside Kenya, however that access arises, before turning to the question of legal basis.

4. LEGAL GROUNDS FOR TRANSFERRING PERSONAL DATA OUTSIDE KENYA

Sections 48 to 50 of the DPA establish a closed set of legal grounds on which personal data may be transferred outside Kenya. A transfer that does not fit within one of these grounds is unlawful, regardless of the commercial necessity that may be said to justify it.

4.1 Adequacy

The first ground is a determination — made by or on the advice of the Cabinet Secretary, informed by the Data Commissioner — that the recipient country has in place appropriate data protection safeguards comparable to those under Kenyan law, or that the recipient is subject to legal obligations, binding corporate rules, or other instruments that provide equivalent protection. As at the time of writing, Kenya has not published a settled, exhaustive list of countries formally confirmed as adequate in the manner of the European Commission's adequacy decisions under the GDPR; organisations should treat adequacy as a case-by-case regulatory determination and monitor ODPC publications for updates rather than assuming any particular jurisdiction is pre-cleared.

4.2 Appropriate Safeguards

In the absence of an adequacy determination, a transfer is lawful where the controller or processor has put in place appropriate safeguards, and the data subject has enforceable rights and effective legal remedies following the transfer. In practice, “appropriate safeguards” are most commonly evidenced through binding contractual clauses between the exporting and importing parties — Kenya's equivalent of the GDPR's standard contractual clauses — supplemented, in group structures, by binding corporate rules, and, increasingly, by independent certifications such as ISO/IEC 27701. The essential legal test is substantive, not merely documentary: the safeguard must, in fact, ensure that the data subject retains a meaningful and enforceable level of protection once the data has left Kenya, including a practical route to remedy if their rights are violated abroad.

4.3 Consent

A transfer may also be grounded in the data subject's consent, provided that consent is freely given, specific, informed, and unambiguous, and that the data subject has been informed of the possible risks of the transfer in the absence of

an adequacy decision or appropriate safeguards. Consent is a narrower and more fragile basis than is often assumed in practice: it must be genuinely optional (an employee cannot meaningfully “consent” to a transfer as a condition of continued employment), and a controller relying on consent bears the burden of demonstrating that the information given to the data subject was adequate to make the consent informed in the specific sense the transfer regime requires.

4.4 Necessity-Based Derogations

The Act preserves a limited set of derogations for transfers that are necessary for the performance of a contract between the data subject and the controller, for the conclusion or performance of a contract in the data subject's interest, for important reasons of public interest, for the establishment, exercise, or defence of a legal claim, or to protect the vital interests of the data subject or others where the data subject is incapable of giving consent. These derogations are, by design, exceptions rather than a general-purpose alternative to the adequacy or safeguards routes, and regulators internationally have consistently cautioned against their routine use as a substitute for proper contractual safeguards.

4.5 Section 50: Sensitive and Strategic Data, and Registration Requirements

Section 50 of the DPA imposes heightened conditions on the transfer of data revealing a data subject's health status, ethnic or social origin, and similar sensitive categories, and on data the Cabinet Secretary designates as relating to Kenya's strategic interests. Transfers of such data require proof that appropriate safeguards are in place and, in some circumstances, the involvement or notification of the Data Commissioner. The Act also reserves to the Cabinet Secretary a power to prescribe that certain categories of data must be processed using a server or data centre located in Kenya, and that at least one serving copy of specified data be stored in Kenya — a data localisation mechanism that organisations handling government, health, financial, or other sensitive data categories should monitor closely, as sectoral instruments continue to develop in this area.

COMMON MISTAKE

Organisations frequently assume that a global vendor's compliance with the GDPR or with international certifications automatically satisfies the DPA's cross-border transfer requirements. It does not. GDPR compliance may be strong evidence of appropriate safeguards, but the Kenyan controller remains independently accountable under Sections 25 to 30 and 48 to 50 of the DPA, and must be able to demonstrate — on Kenyan legal grounds, in a form the ODPC would recognise — why the specific transfer at issue is lawful.

CASE IN FOCUS

Aaditi Rajput v Diamond Trust Bank Kenya Limited & Diamond Trust Bank Uganda Limited

Office of the Data Protection Commissioner, Determination (2025)

Facts

A Kenyan bank customer received monthly bank statements belonging to a Ugandan customer of an affiliated bank in the same regional group, revealing an inadvertent cross-border disclosure of personal data between the group's Kenyan and Ugandan entities.

Regulatory Response

Because Diamond Trust Bank Uganda fell outside the ODPC's direct jurisdiction, the Commissioner formally sought assistance from Uganda's Personal Data Protection Office, which conducted its own inquiries, obtained a response from the Ugandan entity, and shared its findings with the ODPC.

Significance

The determination establishes a practical model for handling cross-border data protection complaints within East Africa, and confirms that a foreign group entity's jurisdictional distance from Kenya does not insulate a regional banking or corporate group from accountability for personal data that moves between its Kenyan and foreign

operations. For procurement and governance teams, the case is a reminder that intra-group data sharing — not only third-party vendor transfers — falls squarely within the Section 48–50 transfer regime.

5. DATA LOCALISATION: EMERGING SECTORAL AND POLICY TRENDS

Kenya's transfer regime coexists with a broader policy conversation about data localisation and “digital sovereignty,” reflected in Section 50's reserved power to mandate in-country processing or storage for prescribed data categories, and in sector-level expectations — particularly in government, financial services, and identity-management contexts — that certain categories of citizen data be retained, at least in part, within Kenyan jurisdiction. Organisations operating in these sectors should track both DPA subsidiary legislation and sector regulator guidance, as localisation obligations are more likely to be introduced through targeted instruments than through wholesale amendment of the general transfer regime.

From a governance perspective, localisation debates should be read as a signal rather than a settled rule: they indicate the direction of regulatory travel and inform how a cautious organisation should weight jurisdictional risk when selecting cloud regions, negotiating data-residency commitments with vendors, and designing systems architecture for new deployments, even where no binding localisation mandate presently applies to the organisation's specific data category.

6. PRACTICAL COMPLIANCE LIFECYCLE FOR CROSS-BORDER TRANSFERS

Sound cross-border transfer governance follows a repeatable lifecycle rather than a single point-in-time exercise. The following seven stages provide a practical methodology that Data Protection Officers, legal counsel, and procurement teams can apply consistently across the organisation's vendor and group-transfer portfolio.

Stage 1 — Data Mapping and Transfer Identification

Identify every instance in which personal data is accessible to, stored by, or processed by a person or system outside Kenya, including remote support access, offshore disaster recovery, sub-processing, and intra-group data sharing. Maintain this as a living register, updated whenever new vendors or system integrations are introduced.

Stage 2 — Legal Basis Assessment

For each identified transfer, determine which of the Section 48–50 grounds applies: adequacy, appropriate safeguards, consent, or a necessity-based derogation. Document the reasoning, since the burden of demonstrating a lawful basis rests with the controller, not the ODPC or the data subject.

Stage 3 — Transfer Risk Assessment

Assess the practical risk the specific transfer poses to data subjects, having regard to the nature and volume of the data, the sensitivity of the categories involved, the legal and political environment of the destination country, the recipient's security posture, and the availability of effective remedies to the data subject in that jurisdiction. Where the processing is high-risk, this assessment should be integrated with, or escalate into, a full Data Protection Impact Assessment.

Stage 4 — Safeguard Selection and Documentation

Select and document the specific safeguard relied upon — contractual clauses, binding corporate rules, certification, or a combination — calibrated to the risk identified in Stage 3. Higher-risk transfers warrant layered safeguards (contractual and technical) rather than reliance on a single mechanism.

Stage 5 — Contracting

Negotiate and execute the data transfer or data processing agreement incorporating the safeguards identified in Stage 4, together with the broader contractual protections discussed in Chapter 8.

Stage 6 – Regulatory Engagement

Where the transfer involves sensitive categories of data, large-scale processing, or falls within a category the ODPC has flagged for closer scrutiny, engage with registration, notification, or consultation requirements as applicable, and retain evidence of that engagement.

Stage 7 – Ongoing Monitoring and Re-Assessment

Cross-border transfer compliance does not end at signature. Organisations should re-assess the legal basis and risk profile of a transfer whenever the destination country's legal environment changes materially, whenever the recipient's sub-processing arrangements change, and at defined periodic intervals as part of the organisation's broader compliance audit programme.

7. VENDOR AND PROCESSOR DUE DILIGENCE FOR CROSS-BORDER ARRANGEMENTS

Due diligence on a foreign recipient of Kenyan personal data should go beyond a general vendor security questionnaire and address transfer-specific risk directly.

- The recipient's corporate structure, group relationships, and the jurisdictions in which it and its sub-processors are established.
- The data protection and cybersecurity legal regime applicable to the recipient, including any laws compelling disclosure to foreign governments or security services.
- Independent certifications such as ISO/IEC 27001 (information security) and ISO/IEC 27701 (privacy information management), and the currency of any audit reports.
- The precise location(s) of data centres and processing facilities, including backup and disaster-recovery sites.
- The existence, identity, and jurisdiction of any sub-processors, and the recipient's process for notifying and obtaining consent to sub-processor changes.
- The recipient's documented incident history, breach notification practices, and its contractual commitment to timely notification of the Kenyan controller.
- The recipient's capacity to support the Kenyan controller in responding to data subject rights requests — access, rectification, erasure, objection — within the timeframes the DPA requires.
- Insurance coverage relevant to data protection and cybersecurity incidents.
- Exit and data-return or deletion arrangements on termination of the relationship.

8. CONTRACTUAL MECHANISMS: TRANSFER CLAUSES AND DATA PROCESSING AGREEMENTS

Kenya's DPA does not yet prescribe a single official set of standard contractual clauses in the manner of the European Commission's clauses under the GDPR. In their absence, organisations typically adapt internationally recognised clause sets — most commonly clauses modelled on the GDPR's standard contractual clauses — to the Kenyan statutory context, ensuring the clauses expressly reference the data subject rights and remedies the DPA guarantees, rather than relying solely on foreign-law concepts that a Kenyan data subject could not straightforwardly invoke.

A well-drafted cross-border data transfer agreement should address, at minimum:

1. The precise scope, purpose, and categories of personal data being transferred, avoiding open-ended or unlimited processing purposes;
2. The safeguard relied upon under Sections 48–50 of the DPA, stated expressly rather than left to implication;
3. Confidentiality and use restrictions binding the recipient and any permitted sub-processors;
4. Security requirements calibrated to the sensitivity of the data, including encryption, access controls, and logging;
5. An obligation on the recipient to notify the Kenyan controller promptly of any personal data breach, request from a foreign authority for disclosure, or legal compulsion affecting the data;
6. Cooperation obligations enabling the Kenyan controller to respond to data subject rights requests within statutory timeframes;
7. Audit and inspection rights, exercisable by the controller or an independent auditor;
8. Sub-processing controls, including prior notification and, where appropriate, consent rights for the Kenyan controller;

9. Data return, deletion, or certified destruction obligations on termination of the arrangement;
10. Liability, indemnity, and governing law provisions that do not strip the Kenyan data subject of an effective, accessible remedy.

PRACTICAL DRAFTING TIP

Resist boilerplate. A transfer clause copied wholesale from a GDPR-facing template will frequently reference the wrong regulator, the wrong statutory rights, and remedies the Kenyan data subject cannot in practice invoke. Every crossborder data transfer agreement should be reviewed to confirm that it operationalises the specific safeguard the Kenyan controller is relying upon under Sections 48–50 of the DPA, not merely a generic international standard.

9. CYBERSECURITY AND TECHNICAL SAFEGUARDS

Legal safeguards for cross-border transfers are only as strong as the technical controls that support them. Organisations should expect, and where possible contractually require, encryption of personal data both in transit and at rest, robust identity and access management governing which offshore personnel and systems may access Kenyan personal data, comprehensive logging and monitoring of cross-border access, and periodic independent security testing of the systems and channels through which the transfer occurs.

The Computer Misuse and Cybercrimes Act imposes obligations relevant to unauthorised access, data interference, and system interference that apply to Kenyan-origin data wherever it is processed, and organisations should ensure their incident response arrangements with offshore processors are calibrated to meet Kenyan reporting expectations, not only those of the recipient's home jurisdiction.

EMERGING ISSUE

The growth of generative artificial intelligence services introduces a distinct cross-border transfer risk: personal data entered into a prompt, or used to fine-tune or ground a foreign-hosted model, may be transferred, retained, or used for model improvement in ways that are opaque to the Kenyan controller and difficult to reverse. Organisations procuring AI services that will process Kenyan personal data should treat the AI vendor's data-handling architecture as a cross-border transfer question in its own right, addressed through the same Section 48–50 analysis applied to any other offshore processor, and should refer to this series' companion note on AI procurement for a fuller treatment.

10. GOVERNANCE AND BOARD OVERSIGHT

Cross-border data transfer risk should be embedded within the organisation's existing enterprise risk management and corporate governance structures rather than managed as an isolated compliance task. The board or its risk or audit committee should receive periodic reporting on the organisation's cross-border transfer register, material new transfer arrangements, jurisdictional risk changes affecting existing transfers, and any transfer-related incidents. The Data Protection Officer should have a direct reporting line for escalation of transfer risk that legal or procurement functions cannot resolve at an operational level, and the organisation's information security function (typically led by a Chief Information Security Officer) should be a standing participant in transfer risk assessments given the close interdependence between legal safeguards and technical controls described in Chapter 9.

GOVERNANCE INSIGHT

Boards should ask, at minimum: which countries currently receive our personal data, on what legal basis, and how would we know if that basis stopped being valid? An organisation unable to answer this question promptly has a data governance gap, irrespective of how sophisticated its contractual templates may be.

11. EMERGING RISKS AND FUTURE DIRECTIONS

Several developments are likely to reshape Kenya's cross-border transfer landscape over the coming years. Continued ratification and operationalisation of the Malabo Convention may, in time, support a more structured intra-African adequacy framework, reducing reliance on bespoke contractual safeguards for transfers within the region. The ODPC's evolving guidance and enforcement practice will progressively clarify the practical meaning of “appropriate safeguards” in the Kenyan context, particularly as more decisions and advisory opinions are published. The growth of cloud concentration among a small number of global hyperscale providers raises structural risk that individual contractual safeguards cannot fully address, and organisations should factor vendor concentration into their broader resilience and business continuity planning. Finally, cross-border processing by generative AI and agentic AI systems — often involving data flows that are difficult to map with precision — will increasingly test the boundaries of a transfer regime built around discrete, identifiable data flows, and organisations should expect regulatory guidance in this area to develop rapidly.

12. PRACTICAL COMPLIANCE CHECKLIST

Before authorising, renewing, or relying upon any cross-border transfer of personal data, organisations should confirm the following:

Mapping and Legal Basis

- ☐ All instances of offshore access to, storage of, or processing of Kenyan personal data have been identified and recorded in a transfer register.
- ☐ A specific legal basis under Sections 48–50 of the DPA has been identified and documented for each transfer.
- ☐ Where consent is relied upon, it is demonstrably free, specific, informed and unambiguous, and the data subject has been told of the risks of the transfer.
- ☐ Necessity-based derogations are used only for genuinely occasional, non-repetitive transfers, not as a standing basis for routine processing.

Risk Assessment

- ☐ A transfer risk assessment (or full DPIA where required) has been completed and considers the destination country's legal environment and the recipient's security posture.
- ☐ Special categories of data and any data falling within Section 50's heightened regime have been separately assessed and, where required, notified to the ODPC.

Contracting and Safeguards

- ☐ A data transfer or data processing agreement is in place, expressly identifying the safeguard relied upon and referencing DPA-specific data subject rights and remedies.
- ☐ Sub-processing, breach notification, audit rights, and data return/deletion on termination are addressed in the contract.
- ☐ Technical safeguards — encryption, access controls, logging — are verified, not merely asserted.

Vendor Diligence

- ☐ The recipient's certifications, incident history, sub-processor arrangements, and data centre locations have been independently verified.
- ☐ The recipient can support Kenyan data subject rights requests within statutory timeframes.

Governance and Monitoring

- ☐ The board or risk committee receives periodic reporting on the cross-border transfer register and material changes to it.
- ☐ A process exists to re-assess transfers when the destination country's legal environment, or the recipient's subprocessing arrangements, change materially.
- ☐ Cross-border transfer compliance is included within the organisation's periodic data protection compliance audit programme.

13. CONCLUSION

Cross-border data transfers are now a structural feature of how Kenyan organisations conduct business, rather than an occasional or exceptional arrangement. The Data Protection Act, 2019 supplies a coherent, if still maturing, legal framework for assessing when such transfers are lawful, but that framework only delivers real protection to data subjects — and real risk mitigation for organisations — when it is operationalised through disciplined data mapping, rigorous legal-basis and risk assessment, carefully drafted contractual safeguards, robust technical controls, and active board-level governance. Organisations that treat cross-border transfer compliance as a continuous lifecycle, rather than a contractual formality completed at the point of vendor onboarding, will be better placed to innovate with confidence, withstand regulatory scrutiny, and preserve the trust of the customers, employees, and counterparties whose personal data crosses Kenya's borders every day.

Author's Perspective

The regulation of cross-border data transfers sits at the intersection of sovereignty, commerce, and individual rights. Kenya's approach — adequacy, safeguards, consent, and narrow derogations, backed by a reserved power to require in-country processing for sensitive categories — reflects a deliberate balance between enabling Kenya's participation in the global digital economy and preserving meaningful protection for Kenyan data subjects once their data leaves domestic jurisdiction. Getting that balance right in practice depends less on the sophistication of any single contractual clause than on the discipline with which organisations map, assess, document, and govern the full lifecycle of their cross-border data flows. As Kenya's data protection jurisprudence and regulatory guidance continue to mature, organisations that have already embedded this discipline will adapt fastest — and face the least disruption — as the framework evolves.

Summary Table

Legal Basis	Sections 48–50 of the DPA — adequacy, appropriate safeguards, consent, or necessitybased derogations
Scope of “Transfer”	Functional, not formal — remote access, disaster recovery, SaaS hosting, and intragroup sharing all qualify
Sensitive Data	Section 50 imposes heightened conditions and potential ODPC notification for sensitive and strategic data categories
Regulatory Precedent	Aaditi Rajput v Diamond Trust Bank (ODPC, 2025) — cross-jurisdictional cooperation with Uganda's PDPO
Contractual Mechanism	GDPR-style standard contractual clauses adapted to reference DPA-specific rights and remedies
Technical Safeguards	Encryption in transit and at rest, access management, logging, and periodic independent security testing
Governance	Board-level reporting on the transfer register, DPO escalation rights, and periodic reassessment
Emerging Risk	Generative and agentic AI systems create transfer flows that are difficult to map and reverse

This Practice Note is prepared for general informational and educational purposes as part of the Kenya Practice and Law Review series on data protection, privacy, and AI governance. It does not constitute legal advice and should not be relied upon as a substitute for advice from qualified Kenyan counsel on the specific facts of any transaction or arrangement.

About the Author

Muchangi Patrick

Advocate of the High Court of Kenya · Founder, Muchangi Patrick & Associates Advocates

Muchangi Patrick advises boards, regulators, and technology companies on data protection, AI governance, and fintech law, and edits the Kenya Practice and Law Review.

KENYA PRACTICE AND LAW REVIEW

A professional publication series providing authoritative guidance on privacy, data protection, and AI governance in Kenya, published by Muchangi Patrick & Associates Advocates.

Data Protection · Cross-Border Transfers · Sections 48–50 DPA · ODPC · Malabo Convention · Kenya